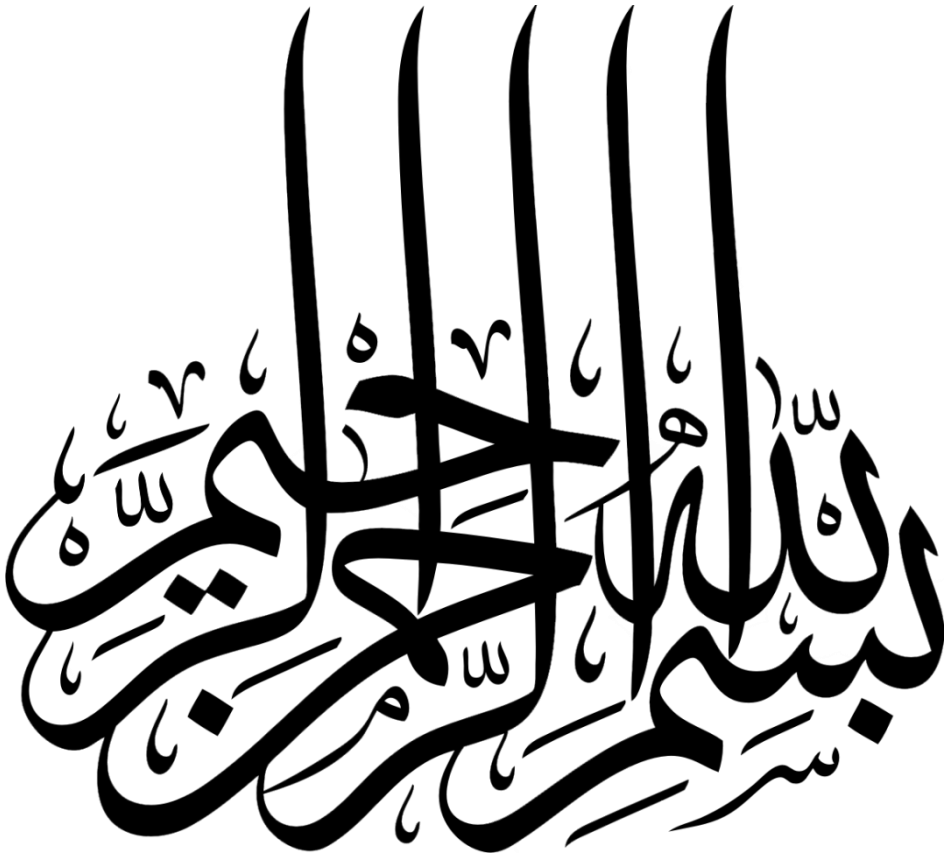

بسم الله الرحمن الرحيم

گزارش تست نفوذپذیری

سامانه sp.fanava.com

مشخصات سند:

کارفرما	پیمانکار	تاریخ نگارش سند
گروه فناوا	دهکده امن فناورانه صبا	۳۰ خرداد ماه ۱۴۰۵

تهیه شده توسط	شماره مستند	طبقه بندی
مدیریت فنی و ارزیابی	TARA-PRO-1405-0330-020	محرمانه

مشخصات شرکت:

آدرس	شماره تماس
تهران – خیابان انقلاب اسلامی – خیابان استاد نجات الهی	۰۲۱-۸۸۹۳۵۹۲۰
کوچه سلمان پاک – پلاک ۱۶ واحد ۴	۰۲۱-۲۸۴۲۶۰۷۸

تمام مطالب مندرج در این سند متعلق به شرکت دهکده امن فناورانه صبا و استفاده از آن منوط به مجوز کتبی از شرکت می‌باشد.



فهرست مطالب

عنوان | صفحه

مقدمه و خلاصه نتایج ۴

متدولوژی آزمون نفوذ ۵

اطلاعات کلی مرتبط با دارایی و محدوده مورد آزمون ۷

محیط ارزیابی ۷

شناسایی وب‌سرور ۷

شناسایی فریم‌ورک‌ها و تکنولوژی‌های فعال روی سامانه ۸

خلاصه مدیریتی ۹

تشریح آسیب‌پذیری‌های کشف شده ۱۲

آسیب‌پذیری بارگذاری فایل با محتوی مخرب ۱۲

آسیب‌پذیری Cross Site Scripting (XSS) - Store ۱۳

آسیب‌پذیری Reverse DoS ۱۳

آسیب‌پذیری عدم مدیریت پیام‌های خطا ۱۳

آسیب‌پذیری Server-Side Request Forgery (SSRF) ۱۳

عدم وجود سرآیندهای امنیتی HTTP ۱۳

آسیب‌پذیری نشت اطلاعات ۱۳

مقدمه و خلاصه نتایج

در دنیای امروز، که هر شرکت یا سازمانی دارایی‌های مختلف حوزه فناوری اطلاعات را در خود جای داده است، امنیت این دارایی‌ها نیز در جایگاه مهمی قرار می‌گیرد. با گسترش روزافزون تهدیدات سایبری و پیچیده‌تر شدن شیوه‌های نفوذ، تکیه بر ابزارهای دفاعی سنتی به تنهایی کافی نیست؛ از این رو، ارزیابی مستمر و شناسایی فعالانه نقاط ضعف پیش از بهره‌برداری توسط مهاجمان، به یکی از ارکان اصلی استمرار کسب‌وکار تبدیل شده است.

در اکوسیستم دیجیتالِ امروز، دارایی‌های فناوری اطلاعات نه تنها زیرساخت تداوم خدمات، بلکه قلب تپنده و حافظ سرمایه‌های استراتژیک سازمان هستند. با این حال، امنیت در فضای سایبری حالتی ایستا ندارد؛ بلکه تابعی است از تکامل مداوم تکنولوژی و هوشمندی تهدیداتی که هر روز پیچیده‌تر و هدفمندتر می‌شوند.

تکیه بر تنظیمات پیش‌فرض یا ابزارهای امنیتی معمول، اگرچه لایه‌ای از حفاظت را ایجاد می‌کند، اما به معنای مصونیت مطلق نیست؛ چرا که نفوذگران همواره به دنبال شناسایی شکاف‌هایی هستند که از دید سیستم‌های نظارتی دور مانده یا به دلیل خطاهای پیکربندی انسانی نادیده گرفته شده‌اند.

ارزیابی امنیتی و تست نفوذ که در این گزارش ارائه شده است، فراتر از یک بررسی سطحی، تلاشی است برای مشاهده‌ی سازمان از دریچه‌ی نگاه مهاجم. هدف ما در این ارزیابی، شناسایی نقاط کور و کشف مسیرهایی است که می‌تواند منجر به دسترسی‌های غیرمجاز یا نشت اطلاعات حساس گردد.

این گزارش حاصل تست نفوذ انجام شده بر روی **وب سایت sp.fanava.com** است که با هدف ارزیابی جامع امنیت دارایی‌های دیجیتال **گروه فناوا** تهیه شده است. هدف از این ارزیابی، شناسایی آسیب‌پذیری‌های امنیتی، تحلیل پیامدهای احتمالی و ارائه راهکارهای عملیاتی جهت کاهش ریسک و ارتقای سطح بلوغ امنیتی زیرساخت‌ها بوده است.

متدولوژی آزمون نفوذ

به منظور حصول اطمینان از دقت، جامعیت و قابلیت بازتولید یافته‌ها، فرآیند ارزیابی امنیتی در این پروژه بر اساس استاندارد جهانی WSTG (Web Security Testing Guide) تدوین‌شده توسط بنیاد امنیتی OWASP در ترکیب با تجربه عملی متخصصان شرکت صورت گرفته است. این چارچوب مرجع، به عنوان استاندارد صنعتی برای تست نفوذ برنامه‌های کاربردی تحت وب، لایه‌های مختلف امنیتی از پیکربندی سرور و مدیریت نشست‌ها گرفته تا کنترل‌های احراز هویت و دسترسی را تحت پوشش قرار می‌دهد.

در اجرای این متدولوژی، مراحل زیر به صورت گام‌به‌گام پیاده‌سازی شده است:

- **فاز شناسایی و جمع‌آوری اطلاعات:** تحلیل ساختار برنامه، شناسایی تکنولوژی‌های مورد استفاده، نقشه‌برداری از سطوح حمله و کشف فایل‌ها و دایرکتوری‌های حساس.
- **فاز تحلیل پیکربندی و کنترل‌های امنیتی:** بررسی تنظیمات امنیتی وب‌سرور، نحوه مدیریت نشست‌ها، مکانیزم‌های احراز هویت و مجوزدهی، و تحلیل نحوه برخورد سیستم با داده‌های ورودی کاربر.
- **فاز شناسایی آسیب‌پذیری‌ها:** اجرای تست‌های هدفمند برای کشف نقاط ضعف در لایه‌های مختلف از جمله تزریق کد، XSS، کنترل‌های دسترسی ناامن و سایر ریسک‌های شناخته شده در استاندارد WSTG.
- **فاز بهره‌برداری و تأیید آسیب‌پذیری شناسایی شده:** تلاش کنترل‌شده برای بهره‌برداری از آسیب‌پذیری‌های شناسایی شده به منظور اثبات صحت آن‌ها و درک میزان اثرگذاری هر ریسک بر روی داده‌ها و عملکرد کلی سیستم.

پس از شناسایی و تأیید آسیب‌پذیری‌ها، جهت تحلیل دقیق و استاندارد سطح ریسک هر یافته، از سیستم امتیازدهی CVSS (Common Vulnerability Scoring System) استفاده شده است. این مدل با در نظر گرفتن فاکتورهای فنی نظیر بردار حمله، میزان پیچیدگی بهره‌برداری و تأثیر بر محرمانگی، یکپارچگی و دسترس‌پذیری اطلاعات، عددی را بین ۰ تا ۱۰ به هر آسیب‌پذیری اختصاص می‌دهد.

بهره‌گیری از CVSS به سازمان کمک می‌کند تا با زبانی مشترک و تخصصی، اهمیت یافته‌ها را درک کرده و فرآیند اصلاح را بر اساس اولویت‌بندی دقیق و منطقی مدیریت نماید. بدین ترتیب، آسیب‌پذیری‌هایی با امتیاز بالاتر، به عنوان اولویت‌های فوری برای تیم فنی جهت کاهش سطح حمله و ارتقای تاب‌آوری سیستم تعیین شده‌اند.

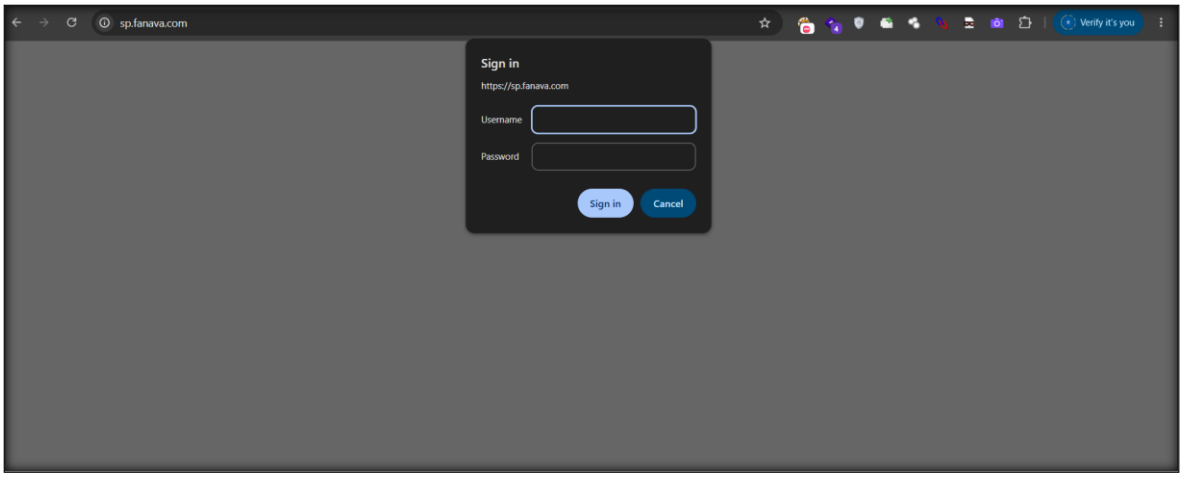
این رویکرد ساختاریافته به تیم ارزیاب اجازه می‌دهد تا فراتر از ابزارهای خودکار، با نگاهی تحلیلی به بررسی پیچیدگی‌های منطقی برنامه بپردازد و اطمینان حاصل کند که تمامی جنبه‌های حیاتی امنیتِ وب‌سایت در برابر تهدیدات پیشرفته مورد سنجش قرار گرفته‌اند.

اطلاعات کلی مرتبط با دارایی و محدوده مورد آزمون

محیط ارزیابی

در این بخش، نمایی از وب‌سایت هدف جهت مستندسازیِ وضعیت سیستم در زمان شروع ارزیابی ارائه شده است. این تصویر به عنوان مرجعی برای تایید دامنه فعالیت و شناسایی بصری رابط کاربریِ سیستمِ تحت تست می‌باشد.

سامانه هدف با آدرس https://sp.fanava.com در حال سرویس‌دهی است که صفحه نخست آن در تصویر زیر نمایش داده شده است:



لازم به ذکر است که نام کاربری pentest به منظور ارزیابی، در اختیار تیم تست نفوذ قرار گرفته است.

نکته: لازم به است این نام کاربری می‌بایست پس از ارسال گزارش به صورت کامل (حساب کاربری به همراه تمام فعالیت‌های آن) از سامانه حذف شود.

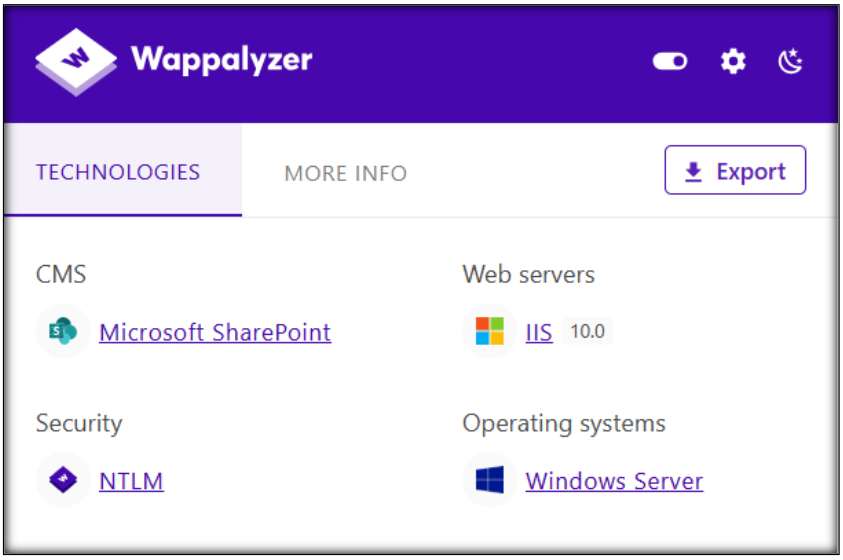
شناسایی وب‌سرور

یکی از مراحل بنیادین در فاز شناسایی، تعیین دقیق نوع و نسخه وب‌سرور میزبان است. تحلیل دقیق پاسخ‌های HTTP (مانند هدرهای Server و X-Powered-By) و بررسی الگوهای رفتاری سرور، به ارزیاب اجازه می‌دهد تا زیرساخت میزبان را به دقت شناسایی کند.

داشتن این اطلاعات، امکان انطباق سیستم با پایگاه داده‌های آسیب‌پذیری‌های شناخته شده (CVEs) را فراهم می‌آورد. در واقع، هدف از این گام، ترسیم نقشه دقیق سطح حمله است تا از طریق استخراج اطلاعات فنی دقیق، بهره‌برداری‌های متناسب با پیکربندی خاص سرور در مراحل بعدی ارزیابی، به‌صورت هدفمند و مؤثر طراحی و اجرا گردد.

شناسایی فریم‌ورک‌ها و تکنولوژی‌های فعال روی سامانه

به منظور شناسایی دقیق زیرساخت و تکنولوژی‌های مورد استفاده در سامانه هدف، از ترکیب روش‌های تحلیل دستی و ابزارهای تحلیل خودکار استفاده شد. در این فرآیند، با بررسی دقیق هدرهای پاسخ HTTP، ساختار کوکی‌ها، نام فیلدهای فرم، و همچنین استفاده از ابزارهای تخصصی انگشت‌نگاری نظیر Wappalyzer، اطلاعات فنی سامانه استخراج گردید. تصویر زیر مربوط به این موضوع می‌باشد:



خلاصه مدیریتی

ارزیابی امنیتی انجام‌شده بر روی سامانه sp.fanava.com نشان می‌دهد که علی‌رغم لایه‌های حفاظتی موجود، چندین شکاف امنیتی با سطوح ریسک متفاوت در معماری و پیاده‌سازی سامانه وجود دارد. شناسایی و بهره‌برداری از این موارد می‌تواند منجر به بروز مخاطرات جدی از قبیل دسترسی غیرمجاز به اطلاعات کاربران، اختلال در دسترس‌پذیری سرویس و در نهایت آسیب به اعتبار سازمانی گردد.

تحلیل وضعیت موجود

یافته‌های این گزارش بر اساس سیستم امتیازدهی CVSS دسته‌بندی شده‌اند تا مدیران و تیم فنی بتوانند فرآیند مقاوم‌سازی را با اولویت‌بندی صحیح آغاز کنند:

- **ریسک‌های سطح زیاد:** این موارد شامل آسیب‌پذیری‌هایی است که اجازه دور زدن کنترل‌های امنیتی اصلی (مانند کپچا) یا اجرای حملات مخرب (مانند بارگذاری فایل‌های غیرمجاز و حملات DoS) را به مهاجم می‌دهد. رفع این موارد به دلیل پتانسیل بالای سوءاستفاده، اولویت نخست سازمان محسوب می‌شود.
- **ریسک‌های سطح متوسط:** این یافته‌ها به شکاف‌هایی در پیکربندی، مدیریت نشست‌ها و اعتبارسنجی ورودی‌ها اشاره دارد. اگرچه این موارد ممکن است به تنهایی منجر به نفوذ کامل نشوند، اما می‌توانند در زنجیره‌ای از حملات، راه را برای نفوذگر هموار سازند.
- **ریسک‌های سطح کم:** مربوط به عدم استفاده از برخی استانداردهای امنیتی HTTP است که اگرچه خطر مستقیم ایجاد نمی‌کنند، اما «لایه دفاعی» سامانه را ضعیف کرده و شناساییِ هدف را برای مهاجم آسان‌تر می‌کنند.

جمع بندی:

در جریان ارزیابی امنیتی انجام شده، مجموعاً ۷ مورد آسیب‌پذیری شناسایی شد که برجسته‌ترین آن‌ها شامل بارگذاری فایل مخرب، امکان اجرای اسکریپت و انکار سرویس با درجه اهمیت **زیاد** است. وجود این حفره‌های بحرانی در کنار ضعف‌های دیگر ریسک بالایی را متوجه سازمان می‌سازد؛ چراکه مهاجم می‌تواند از طریق آن‌ها به زیرساخت‌های سرور نفوذ کرده، باعث توقف سرویس‌دهی (Denial of Service) شود و یا با سرقت نشست‌های کاربری، به داده‌های حساس دسترسی پیدا کند.

در مجموع، وضعیت فعلی سامانه به دلیل پتانسیل بالای اجرای کدهای مخرب (در صورت دسترسی به حساب‌های داخلی)، در سطح آسیب‌پذیر زیاد **متوسط رو به بالا** ارزیابی می‌شود. لذا ضروری است اصلاح فرآیندهای اعتبارسنجی ورودی، محدودسازی دسترسی‌های سمت سرور و پیاده‌سازی سرآیندهای امنیتی HTTP در اولویت تیم فنی قرار گیرد تا از وقوع نشت اطلاعات و مخاطرات امنیتی جبران‌ناپذیر جلوگیری شود.

همچنین لازم به ذکر است که آسیب‌پذیری‌های سطح ریسک متوسط و کم نباید نادیده گرفته شده و با توجه به تجمیع برخی از آن‌ها، امکان سوء استفاده از این سطح آسیب‌پذیری‌ها در صورت عدم رفع، وجود خواهد داشت.

خلاصه یافته‌های ارزیابی



در جدول زیر، تمامی آسیب‌پذیری‌های شناسایی‌شده در طول ارزیابی امنیتی، بر اساس شدت ریسک و طبق CVSS دسته‌بندی شده‌اند. این طبقه‌بندی به سازمان کمک می‌کند تا با نگاهی کلان، اولویت‌های اصلی امن‌سازی خود را شناسایی و منابع فنی را به بهینه‌ترین شکل برای رفع آن‌ها تخصیص دهد.

درجه اهمیت	توضیح آسیب‌پذیری
زیاد	آسیب‌پذیری بارگذاری فایل با محتوای مخرب
زیاد	آسیب‌پذیری Cross Site Scripting (XSS) - Stored
زیاد	آسیب‌پذیری Reverse DoS
متوسط	آسیب‌پذیری عدم مدیریت پیام‌های خطا
متوسط	آسیب‌پذیری Server-Side Request Forgery
کم	عدم وجود سرآیندهای امنیتی HTTP
کم	آسیب‌پذیری نشت اطلاعات

توصیه

شایان ذکر است آسیب‌پذیری‌های گزارش‌شده در بخش‌های آتی، به عنوان نمونه‌های شاخص از وضعیت امنیتی سامانه ارائه شده‌اند. از این رو، اکیداً توصیه می‌شود تیم فنی سازمان، راهکارهای اصلاحی ارائه‌شده را نه تنها برای نمونه‌های تست‌شده، بلکه به صورت جامع در تمامی بخش‌ها و ماژول‌های مشابه در کل سامانه اعمال نمایند تا از بروز شکاف‌های امنیتی مشابه در سایر نقاط سیستم جلوگیری شود.

همچنین با توجه به ماهیت تجاری سامانه مورد ارزیابی و محدودیت‌های عملیاتی در اعمال تغییرات ساختاری، اکیداً توصیه می‌شود فرآیند به‌روزرسانی و وصله‌امنیتی در بازه‌های زمانی کوتاه‌مدت و به صورت مستمر اجرایی گردد. همچنین، جهت پوشش شکاف‌های امنیتی موجود و کاهش ریسک ناشی از آسیب‌پذیری‌های شناسایی‌شده، استقرار یک **دیواره آتش اپلیکیشن‌های وب (WAF)** به عنوان یک لایه دفاعی مکمل، نقشی حیاتی در خنثی‌سازی حملات و ارتقای سطح پایداری سامانه ایفا خواهد کرد.

تشریح آسیب‌پذیری‌های کشف شده

در ادامه، برای آسیب‌پذیری‌های کشف‌شده در سامانه، توضیحات تکمیلی مرتبط ارائه شده است:

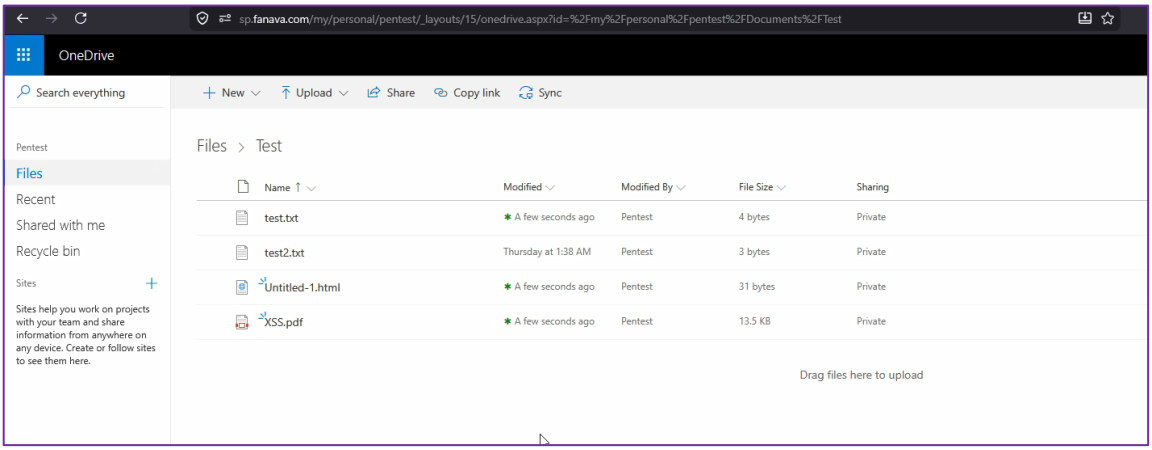
آسیب‌پذیری بارگذاری فایل با محتوی مخرب

مهاجم می‌تواند با بارگذاری فایل مخرب در سامانه منجر به آلوده شدن سرور و یا در شرایطی خطرناک‌تر ایجاد یک Backdoor در سمت سرور شود.

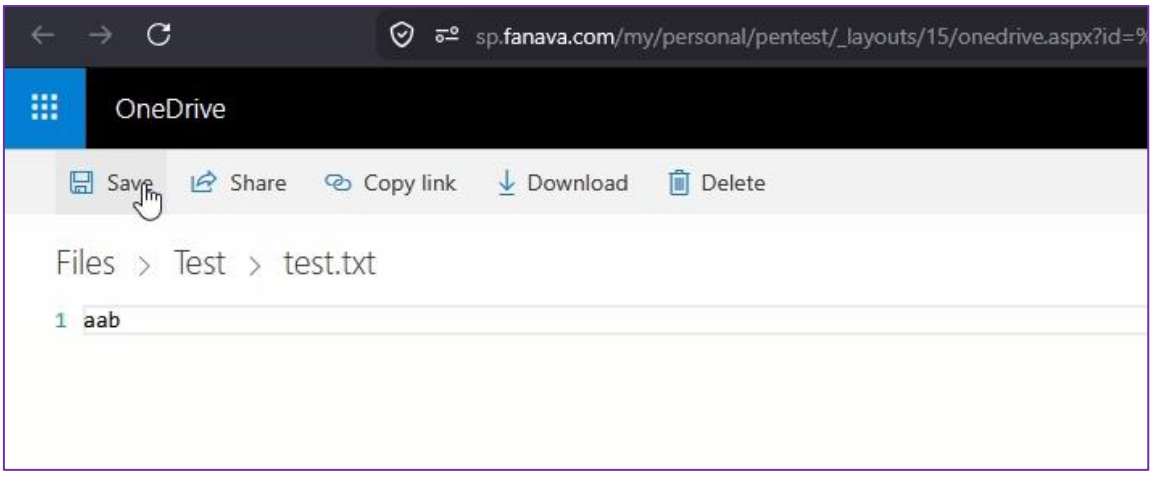
شواهد اثبات آسیب پذیری

با توجه به بررسی‌های انجام شده بر روی سامانه، در بخش بارگذاری فایل در one drive امکان بارگذاری فایل با هر پسوند و محتوایی وجود دارد. نکته‌ای که در این آسیب‌پذیری وجود دارد با دستکاری درخواست ویرایش فایل متنی امکان تغییر مسیر بارگذاری فایل وجود دارد.

تصویر زیر بخش فایل‌های بارگذاری شده در پنل OneDrive سامانه نمایش داده شده است:



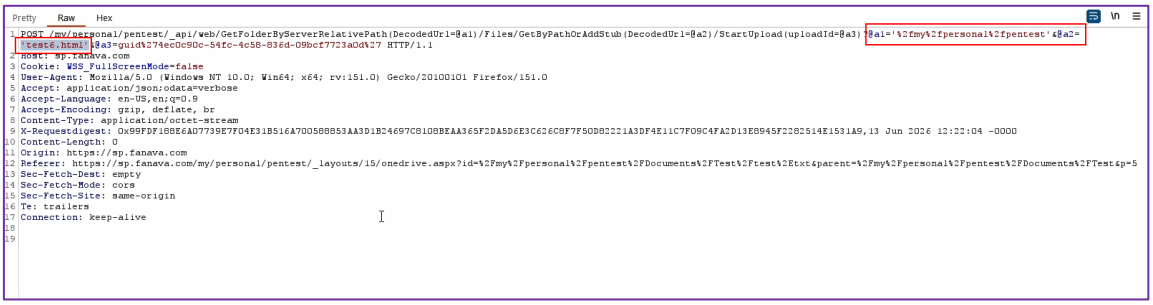
کاربر بر روی یک فایل متنی کلیک می‌کند و گزینه مربوط به ویرایش را کلیک می‌کند:



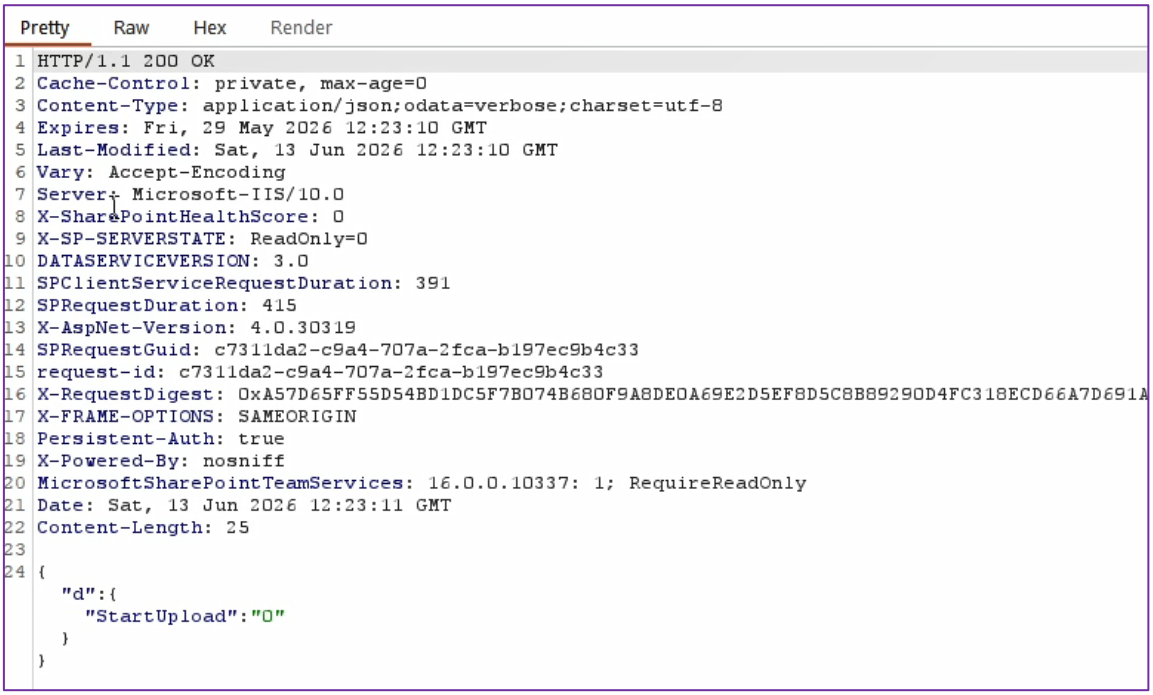
درخواست ذخیره فایل به شرح زیر می‌باشد:



مهاجم در این درخواست مسیر ذخیره فایل را تغییر می‌دهد و همچنین امکان تغییر پسوند فایل در این مرحله وجود دارد:



پاسخ این درخواست در تصویر زیر قابل مشاهده می‌باشد:



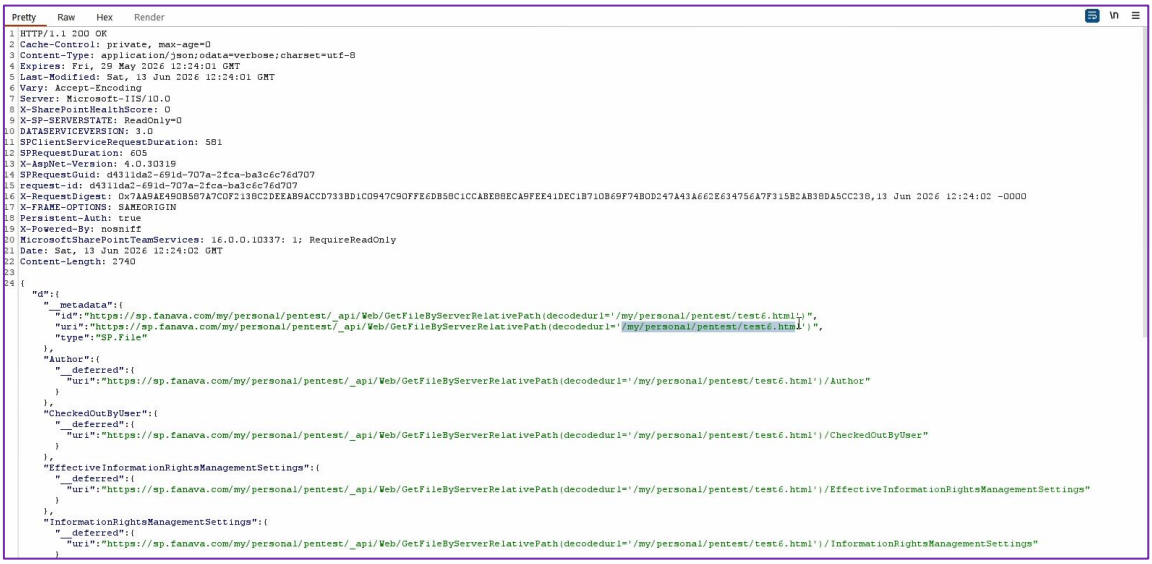
درخواست زیر برای بررسی محتوای فایل مورد استفاده قرار می‌گیرد. همان‌طور که در تصویر زیر قابل مشاهده است مقادیر پیش‌فرض برای مسیر و نام فایل در این بخش قرار دارد:



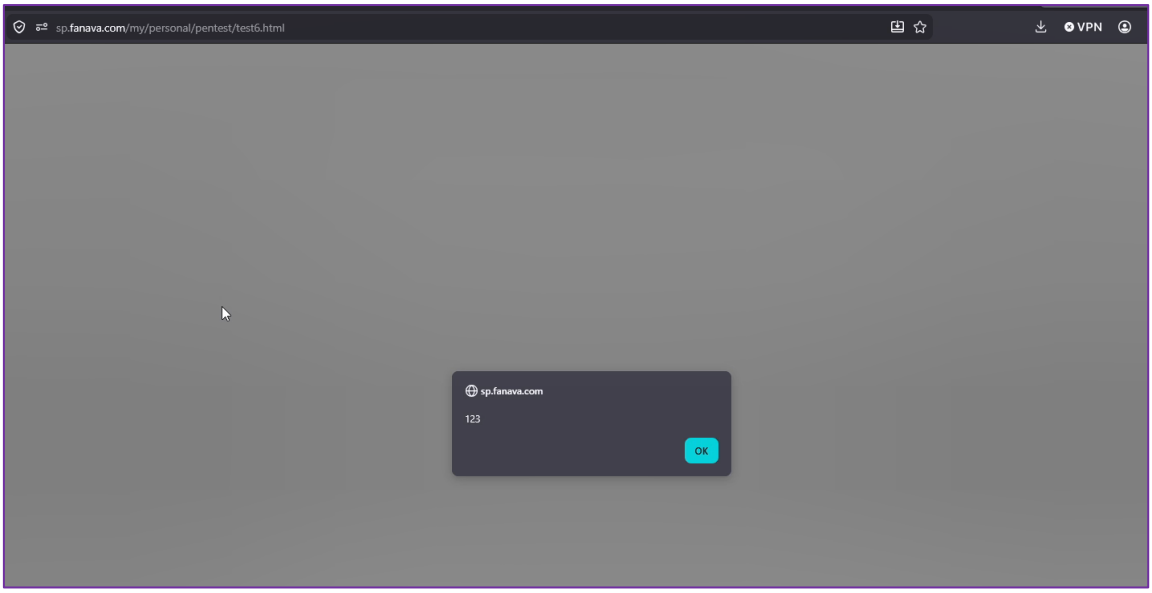
مهاجم در این درخواست نیز مسیر و نام فایل را تغییر می‌دهد و محتوای مد نظر خود را قرار می‌دهد:



تصویر زیر پاسخ این درخواست را نشان می‌دهد. همان‌طور که قابل مشاهده است فایل با موفقیت بر روی مسیر مد نظر مهاجم در سامانه بارگذاری شده است:

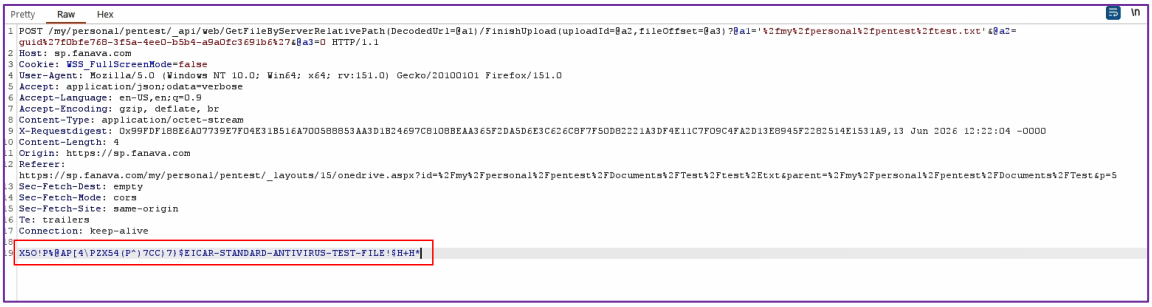


تصویر زیر وجود فایل در مسیر مد نظر مهاجم را نشان می‌دهد:

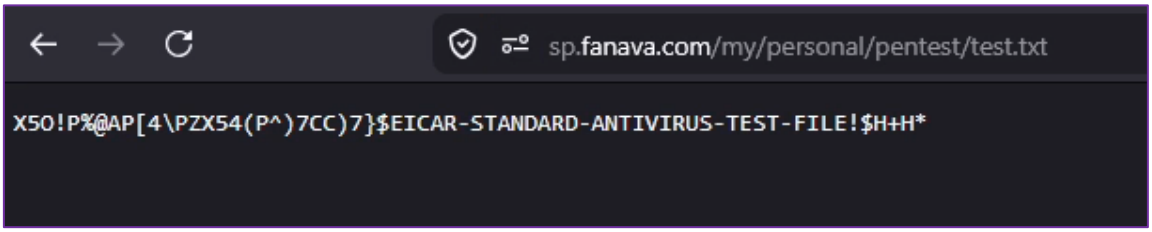


امکان قرار دادن هر فایل با هر پسوندی از این طریق وجود دارد. در تصویر زیر یک فایل تست ویروس eicar در درخواست مربوط به قرار دادن محتوا قابل مشاهده می‌باشد:





تصویر زیر فایل eicar که در واقع یک فایل مخرب می‌باشد، بارگذاری شده نمایش داده شده است:



راهکار پیشنهادی

جهت رفع این آسیب‌پذیری، پیشنهاد می‌شود تا موارد زیر مد نظر قرار گیرد:

- تشخیص نوع فایل‌ها قبل از بارگذاری فایل
- اسکن فایل جهت جلوگیری از بارگذاری ویروس‌ها
- محتوای فایل مطابق با فرمت فایل ارسالی باشد و از ارسال فایل‌هایی که محتوی آن با فرمت آن‌ها مطابقت ندارد جلوگیری شود.

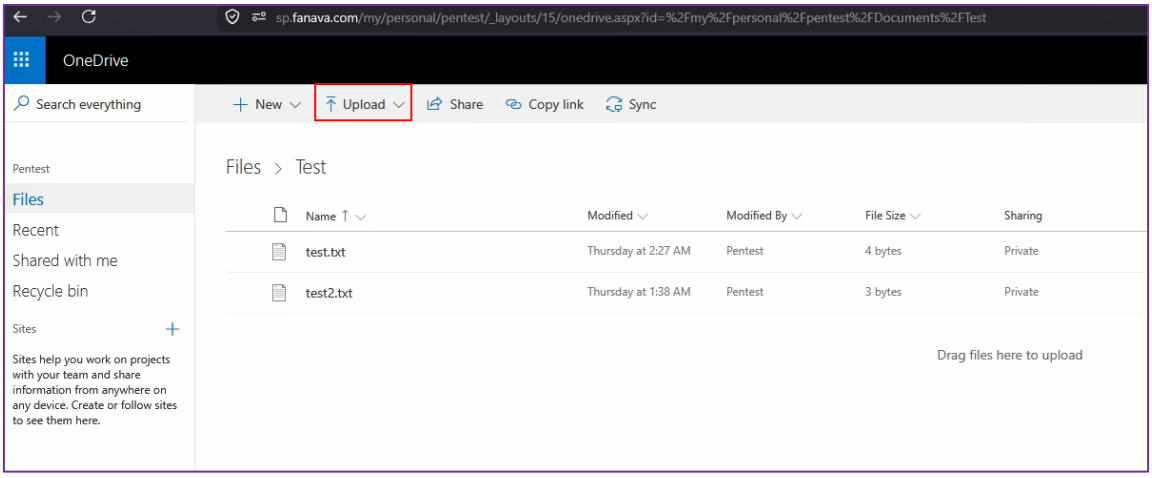
آسیب‌پذیری Cross Site Scripting (XSS) - Store

در صورتی که سامانه در فیلدهای ورودی اطلاعات خود، مانند بخش جستجوی سامانه، اعتبارسنجی مناسبی بر روی داده‌های ورودی انجام ندهد، امکان بروز این آسیب‌پذیری برای کاربر وجود دارد. اگر یک سامانه دارای این آسیب‌پذیری باشد و مهاجم بتواند پیلود مخرب خود را در ورودی‌ها وارد کند، کاربر به محض متصل شدن به صفحه آسیب‌پذیر، کد مخرب مورد نظر مهاجم را از طریق مرورگر خود اجرا می‌کند و اطلاعات حساس قربانی از این طریق برای مهاجم ارسال می‌شود. در نوع Stored، کد جاوا اسکریپت مخرب روی دیتابیس وب‌سایت آسیب‌پذیر ذخیره می‌شود و هر بار صفحه آسیب‌پذیر لود شود، پیلود مخرب مهاجم اجرا می‌شود.

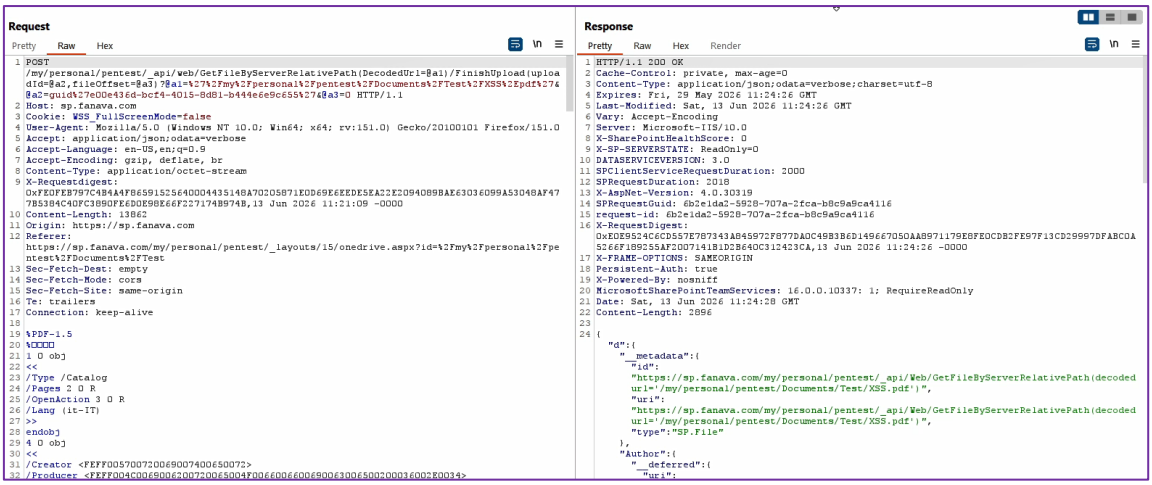
شواهد اثبات آسیب پذیری

با توجه به بررسی‌های انجام شده بر روی سامانه در بخش OneDrive سامانه، امکان بارگذاری فایل HTML وجود دارد اما پیلود موجود در این فایل اجرا نمی‌شود تنها محتوای متنی آن نمایش داده می‌شود. اما در صورتی که پیلود مخرب XSS در داخل یک فایل PDF قرار گیرد، امکان preview کردن آن وجود دارد که در آن پیلود مد نظر مهاجم اجرا می‌شود.

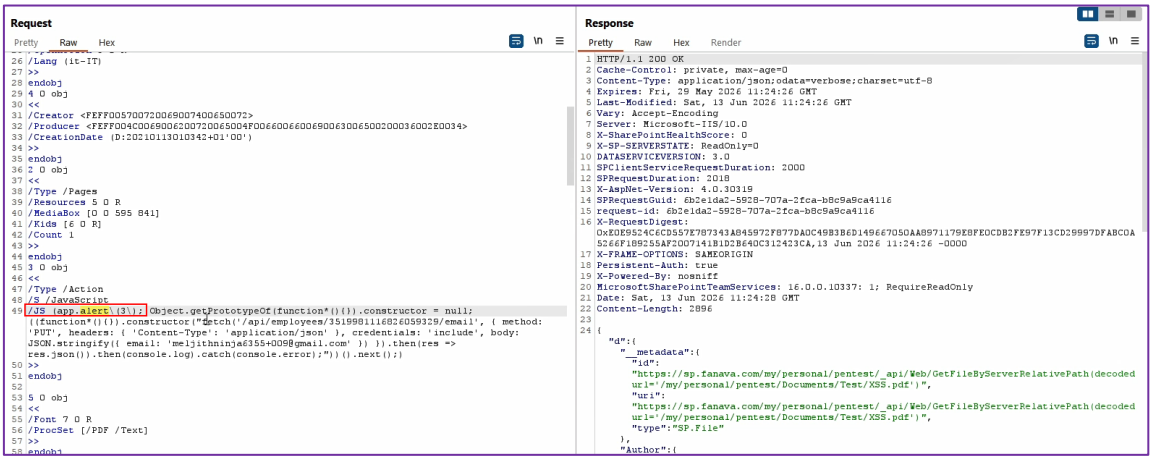
در تصویر زیر بخش OneDrive نمایش داده شده است. با کلیک بر روی گزینه Upload امکان بارگذاری فایل PDF وجود دارد:



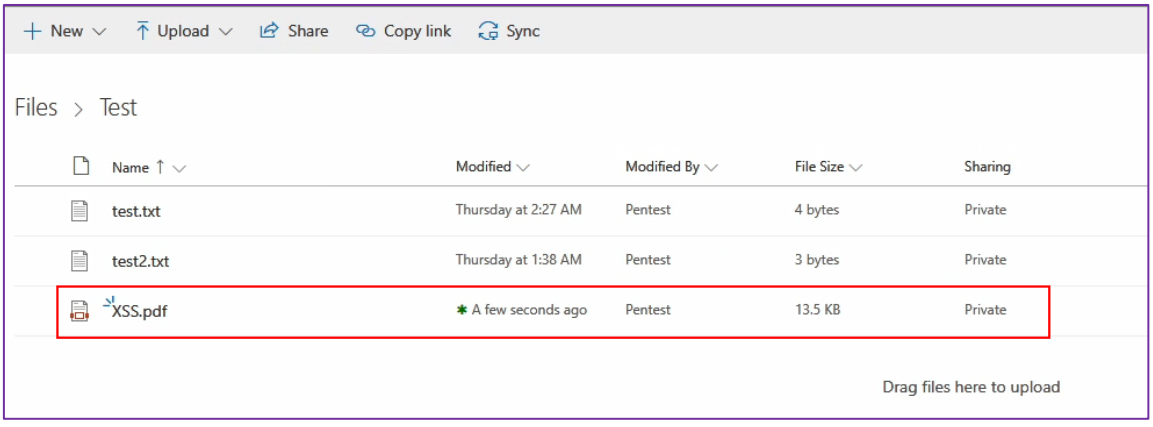
درخواست بارگذاری فایل در تصویر زیر نمایش داده شده است:



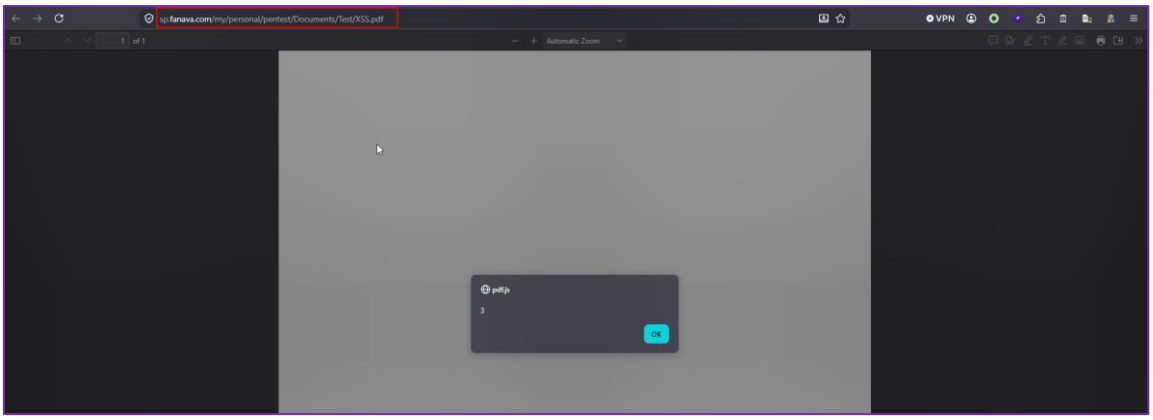
پیلود مخرب مهاجم در ادامه درخواست نمایش داده شده است:



کاربر در تصویر زیر بر روی فایل PDF کلیک می‌کند:



در تصویر زیر اجرای پیلود XSS در صفحه نمایش داده شده است:



راهکار پیشنهادی

جهت رفع این آسیب‌پذیری، پیشنهاد می‌شود تا موارد زیر مد نظر قرار گیرد:

- Sanitization بر روی ورودی‌های کاربر اعمال گردد.
- برای ورودی‌های کاربر در سمت سرویس‌دهنده از لیست حروف مجاز و غیرمجاز استفاده نمود.
- استفاده از Html.Encode در سازوکار پیاده‌سازی صفحات سمت مشتری و کد سمت سرویس دهنده

استفاده از کتابخانه‌های کدگذاری امن جهت HTML Entity Encoding مانند Microsoft Anti-Cross Site Scripting Library برای .NET paltforms.

استفاده از OWASP Java Encoder Project کتابخانه کدگذاری امن با عملکرد بالا را برای زبان JAVA فراهم می‌کند.

استفاده از Escape Syntax برای قسمت‌هایی از HTML Document که امکان ورود داده‌های غیرمجاز در آنها موجود می‌باشد.

تعدادی از قوانین جلوگیری از حمله XSS:

- ورودی‌های نامتعارف / غیرمجاز نباید در هیچ یک از ورودی‌های سمت کاربر پذیرفته شوند مگر در جاهایی که مجاز باشد.

به طور مستقیم در script:

```
<script>...NEVER PUT UNTRUSTED DATA HERE...</script>
```

داخل HTML Comments:

```
<!--...NEVER PUT UNTRUSTED DATA HERE...-->
```

داخل نام مشخصه:

```
<div ...NEVER PUT UNTRUSTED DATA HERE...=test />
```

داخل Tag:

```
<NEVER PUT UNTRUSTED DATA HERE... href="/test" />
```

داخل کدهای CSS:

```
<style>
…NEVER PUT UNTRUSTED DATA HERE…
</style>
```

- Escape، قبل از ورود داده‌های غیرمجاز در محتوا HTML Element

```
<body>
...ESCAPE UNTRUSTED DATA BEFORE PUTTING HERE...
</body>

<div>
...ESCAPE UNTRUSTED DATA BEFORE PUTTING HERE...
</div>
```

آسیب‌پذیری Reverse DoS

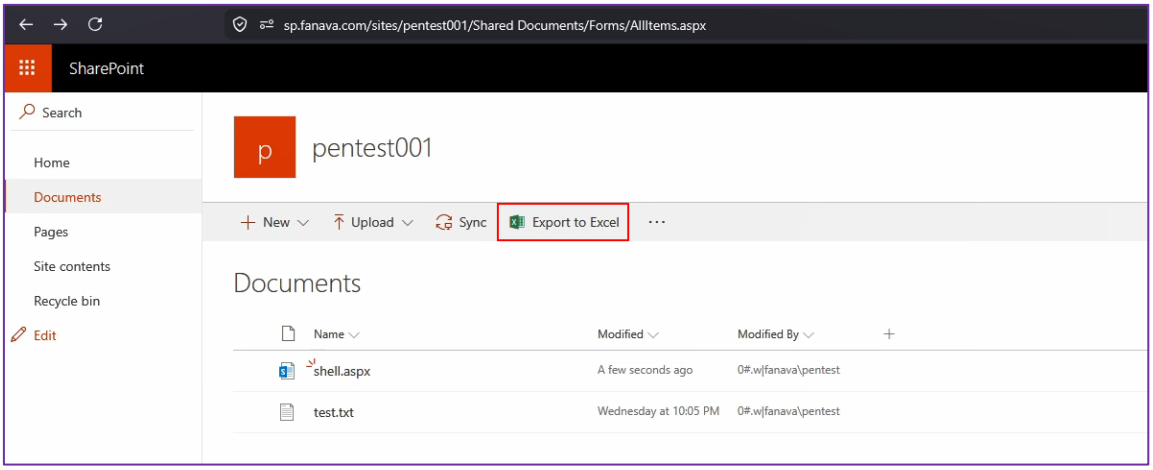
این نوع حملات مانند حمله منع خدمت یا همان DOS هستند با این تفاوت که ترافیکی که سبب از کار انداختن سرور می‌شود از طریق داده‌هایی است که از سمت سرور برای کاربر ارسال می‌شوند به همین دلیل به آن Reverse DoS گفته می‌شود.

شواهد اثبات آسیب پذیری

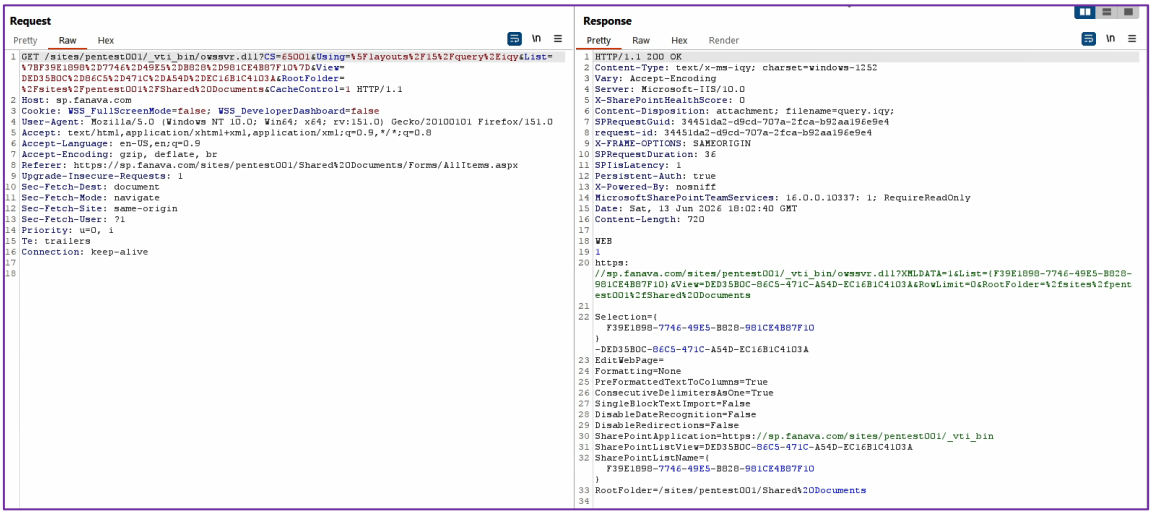
با توجه به بررسی‌های انجام شده بر روی سامانه، در بخش Export گرفتن از محتویات یک سایت در SharePoint به Excel، مسیر root Folder در پاسخ درخواست دوبار نمایش داده می‌شود. در این ورودی کنترلی بر روی درستی و یا نادرستی مسیر Root Folder وجود ندارد و امکان قرار دادن هر مقداری وجود دارد. همچنین در درخواست Export امکان تغییر درخواست از Get به Post وجود دارد. با ترکیب این دو مورد و قرار دادن تعداد بسیار زیادی junk value در ورودی RootFolder امکان بالا بردن زمان پاسخ‌دهی و حجم آن وجود دارد.

به دلیل عملیاتی بودن سامانه تنها نوع اجرای حمله و POC وجود آسیب‌پذیری شرح داده شده است.

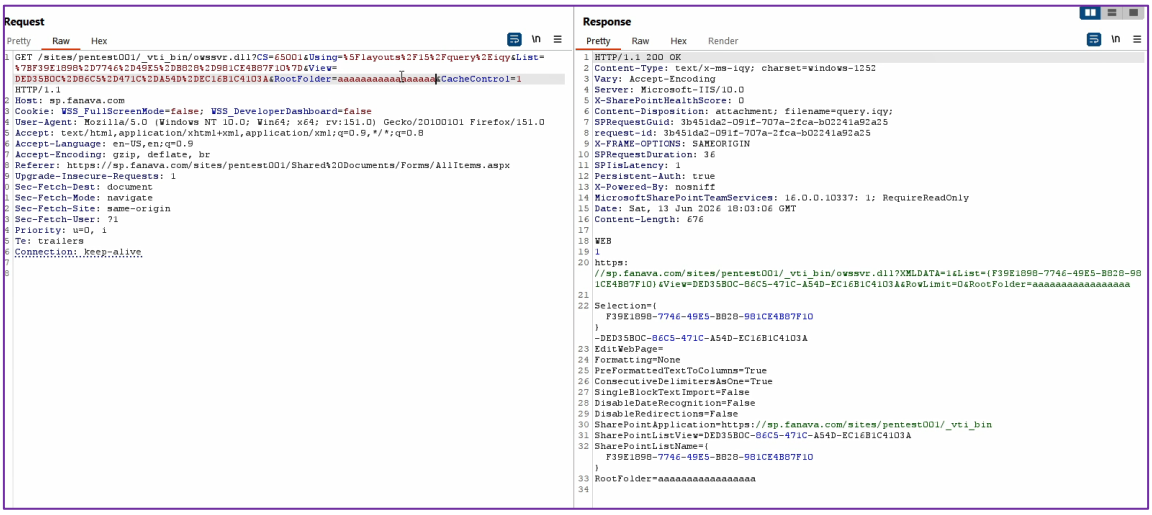
تصویر زیر بخش Documents سایت را نشان می‌دهد. همان‌طور که در این تصویر قابل مشاهده است امکان Export گرفتن محتوای این صفحه به Excel وجود دارد:



درخواست Export گرفتن در حالت عادی به شرح زیر است:

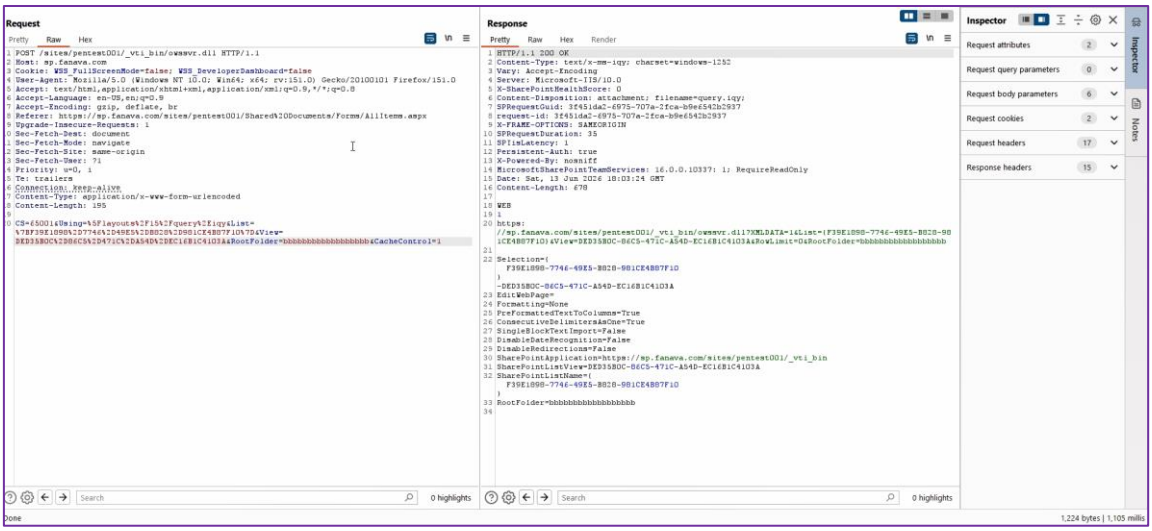


در این درخواست مهاجم ابتدا مقدار RootFolder را یک مقدار نامعتبر وارد می‌کند. همان‌طور که در تصویر زیر قابل مشاهده است درخواست با موفقیت به سمت سامانه ارسال شده و پاسخ آن در خروجی نمایش داده شده است:

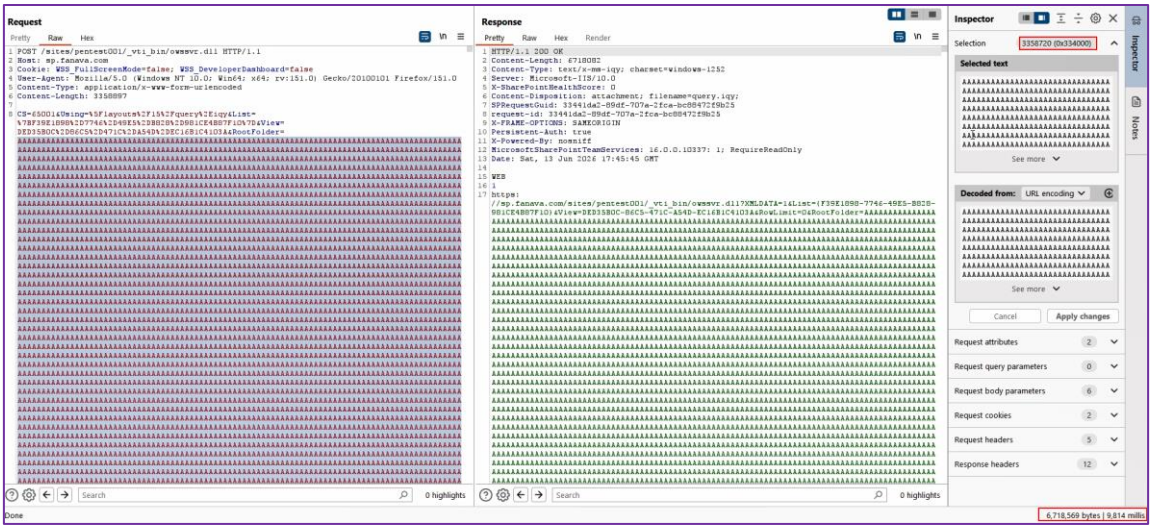


از آنجایی که امکان وارد کردن تعداد زیادی مقادیر نامعتبر در درخواست Get وجود ندارد مهاجم نوع درخواست را از Get به Post تغییر می‌دهد و درخواست را به سمت سامانه ارسال می‌کند.

همان‌طور که در تصویر زیر قابل مشاهده می‌باشد هیچ مکانیزمی برای جلوگیری از تغییر نوع درخواست از Get به Post وجود ندارد:



حال مهاجم به اندازه حدود ۳ مگابایت مقدار A در ورودی RootFolder قرار می‌دهد و درخواست را به سمت سامانه ارسال می‌کند. همان‌طور که در پاسخ این درخواست نمایش داده شده است حجم پاسخ به حدود ۲ برابر این مقدار افزایش یافته و همچنین زمان پاسخگویی سامانه از حالت عادی به ۱۰ ثانیه افزایش یافته است:



راهکار پیشنهادی

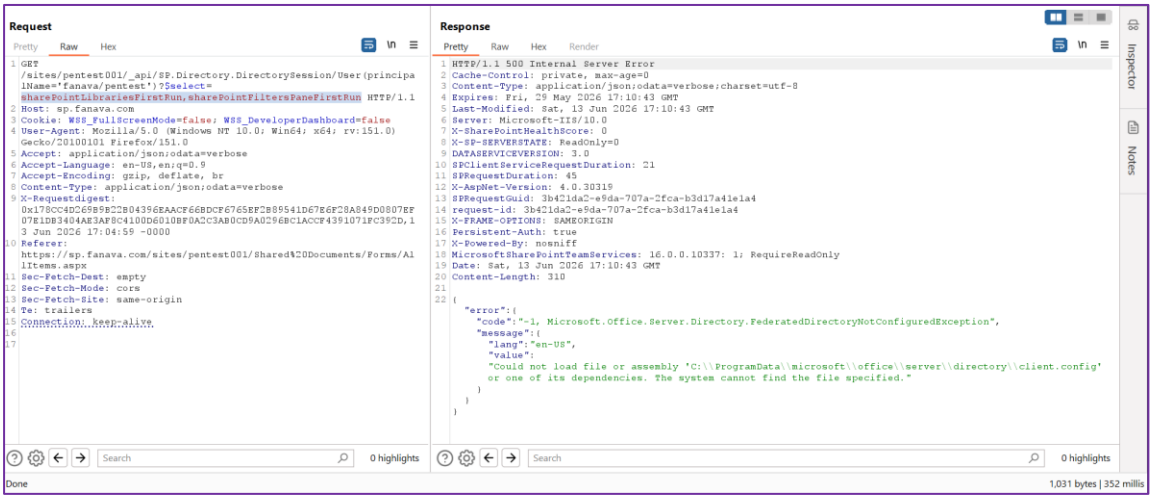
به منظور رفع این آسیب‌پذیری، پیشنهاد می‌شود اطلاعات صفحات سامانه به صورت محدود به سمت کاربر ارسال شوند و همچنین مکانیزم‌های امنیتی برای جلوگیری از ارسال درخواست‌های متوالی به سمت سامانه مانند waf پیاده سازی شود.

آسیب‌پذیری عدم مدیریت پیام‌های خطا

معمولا در طی فرایند بررسی نفوذپذیری سامانه، با کدهای خطایی مواجه می‌شویم که می‌تواند اطلاعات بسیار ارزشمندی درباره نوع و نسخه تکنولوژی‌های استفاده شده در سامانه را در اختیار نفوذگر قرار دهد.

شواهد اثبات آسیب پذیری

با توجه به بررسی‌های انجام شده بر روی سامانه یکی از درخواست‌های سامانه در حالت عادی دارای خطا با کد ۵۰۰ می‌باشد که در خروجی آن مسیر داخلی مربوط به فایل کانفیگ کلاینت نمایش داده شده است:



راهکار پیشنهادی

به منظور رفع این آسیب‌پذیری، پیشنهاد می‌شود برای نمایش خطاها از صفحات شخصی سازی شده استفاده شود تا از افشای اطلاعات درباره نوع و نسخه وب سرور سامانه جلوگیری کند.

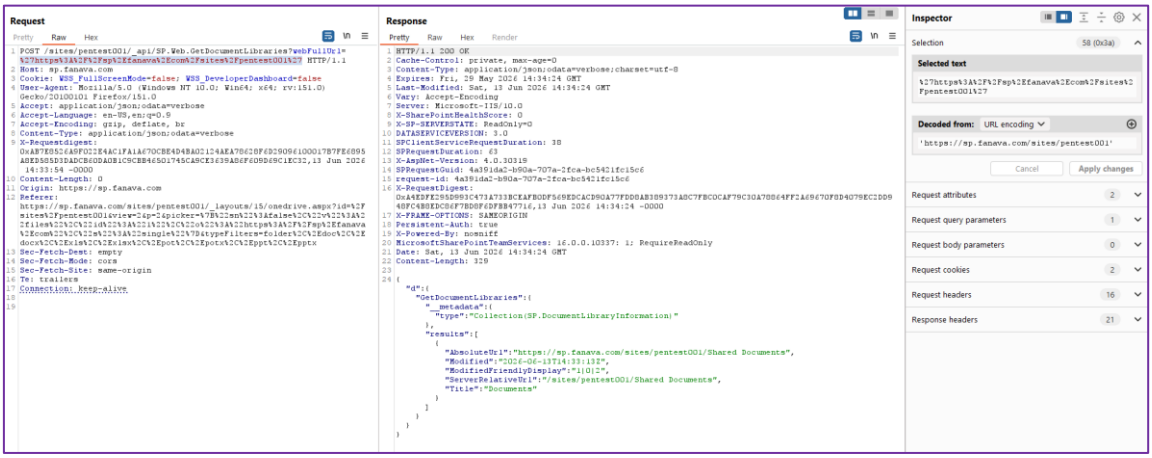
آسیب‌پذیری Server-Side Request Forgery (SSRF)

SSRF (Server-Side Request Forgery) زمانی رخ می‌دهد که یک برنامه وب، آدرس یا منبعی را از کاربر دریافت کرده و بدون اعتبارسنجی مناسب از سمت سرور به آن درخواست ارسال کند. در این شرایط، مهاجم می‌تواند سرور را وادار کند به سرویس‌های داخلی، آدرس‌های حساس یا منابع غیرمجاز درخواست بفرستد. به زبان ساده مهاجم سرور را مجبور می‌کند به جاهایی درخواست بزند که نباید به آن‌ها دسترسی داشته باشد.

شواهد اثبات آسیب پذیری

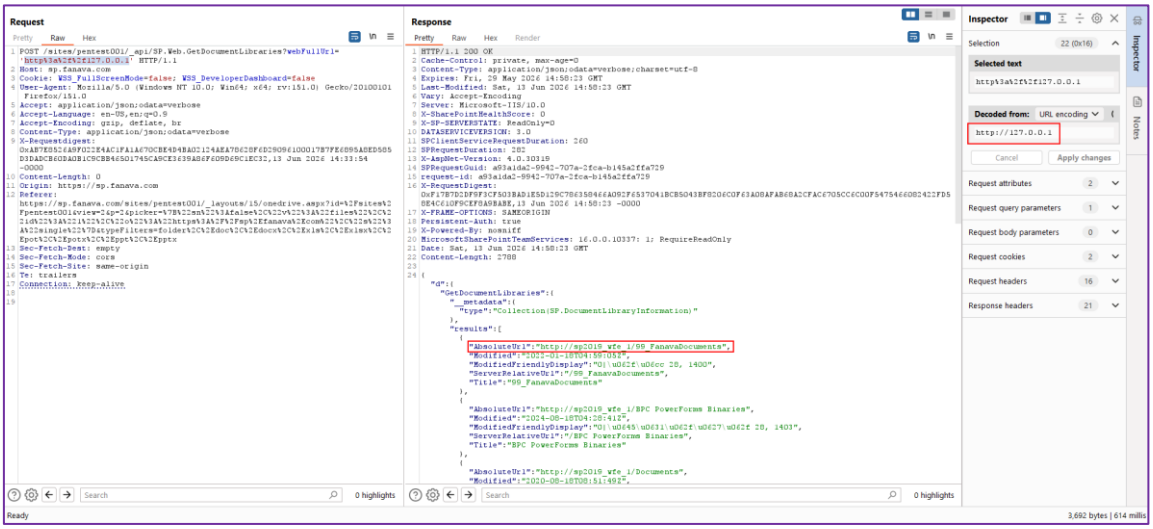
با توجه به بررسی‌های انجام شده در سامانه، در درخواست مربوط به مشاهده فایل‌های LibraryDocument امکان وارد کردن آدرس http://127.0.0.1 وجود دارد. با وارد کردن این مقدار نام داخلی سرور و همچنین مسیرهای LibraryDocument سامانه وجود دارد.

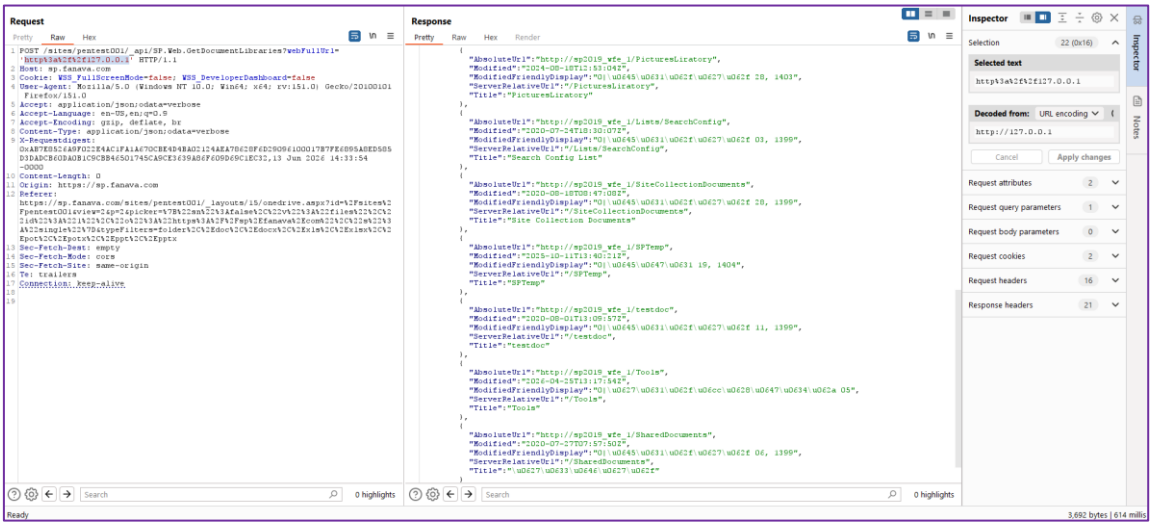
تصویر زیر درخواست نمایش فایل‌های LibraryDocument در حالت عادی را نمایش می‌دهد:



تصاویر زیر تغییر ورودی webFullUrl از مقدار عادی خود به http://127.0.0.1 را نشان می‌دهد.

همان‌طور که در تصاویر زیر قابل مشاهده است نام داخلی سرور و برخی LibraryDocumentهای سامانه نمایش داده شده است:





راهکار پیشنهادی

جهت رفع این آسیب‌پذیری، پیشنهاد می‌شود تا موارد زیر مد نظر قرار گیرد:

- استفاده از Allow-list برای URLها، دامنه‌ها و پروتکل‌های مجاز
- مسدودسازی دسترسی به IPهای داخلی و رزرو شده (مثل localhost، ۱۲۷.۰.۰.۱، ۱۶۹.۲۵۴.۱۶۹.۲۵۴)
- غیرفعال‌سازی یا محدودسازی پروتکل‌های خطرناک (file://، gopher:// و ...)
- اعتبارسنجی و نرمال‌سازی کامل ورودی URL
- اجرای درخواست‌های خارجی در شبکه یا سرویس ایزوله
- مانیتور و لاگ‌گیری از درخواست‌های خروجی سرور

عدم وجود سرآیندهای امنیتی HTTP

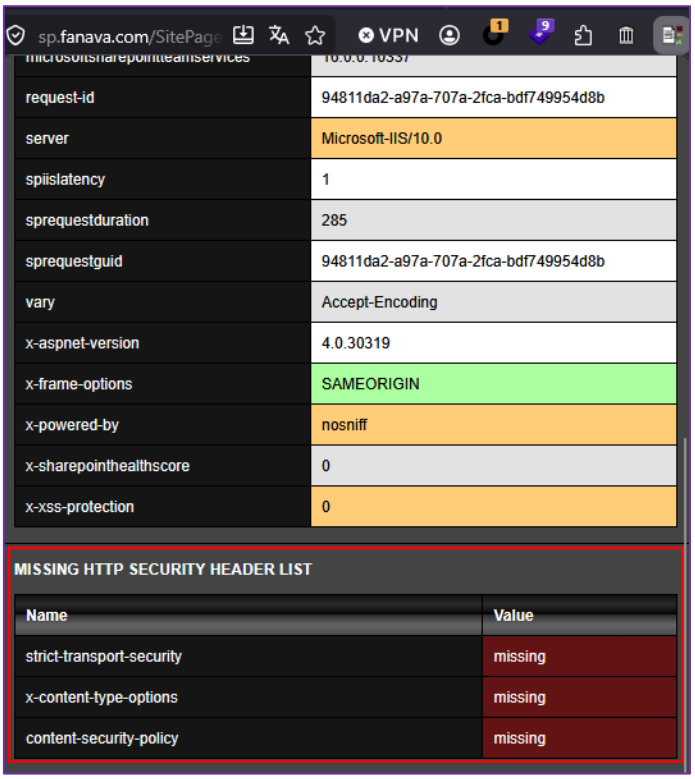
سرآیندهای امنیتی، مجموعه سرآیندی‌هایی هستند که در پاسخ وب‌سرور به سمت مرورگر کاربر ارسال می‌گردند که اغلب باعث افزایش امنیت کاربر در تعامل با سامانه می‌شوند و در صورت غیرفعال بودن هر یک از سرآیندها امکان به وقوع پیوستن حملاتی چون Clickjacking، XSS و... را به همراه دارد.

شواهد اثبات آسیب پذیری

با توجه به بررسی‌های انجام شده بر روی سرایندهای ارسالی در درخواست‌های سامانه، سرایندهای زیر در سامانه وجود ندارند:

Strict-Transport-Security, X-Content-Type-Options, Content-Security-Policy

تصویر زیر بررسی سرایندهای سامانه را نشان می‌دهد:



راهکار پیشنهادی

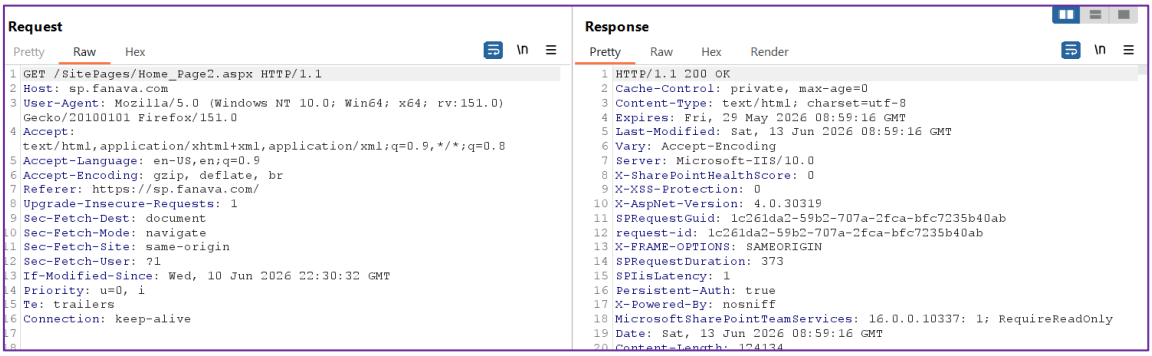
در فایل پیکربندی سامانه سرآیندهای ذکر شده را تنظیم کنید.

آسیب‌پذیری نشت اطلاعات

درصورتی‌که مهاجم بتواند اطلاعات دقیقی در مورد سیستم‌عامل، وب‌سرور، برنامه‌های مورد استفاده، تکنولوژی‌های مورد استفاده و غیره استفاده شده در سامانه به‌دست آورد، این اطلاعات می¬تواند مقدمه‌ای برای نفوذهای بعدی او باشد.

شواهد اثبات آسیب پذیری

با توجه به بررسی‌های انجام شده بر روی سامانه، از طریق بررسی سرایند server و X-AspNet-Version و MicrosoftSharePointTeamServices امکان به دست آوردن اطلاعات درباره نسخه IIS و net. سامانه قابل مشاهده می‌باشد:



راهکار پیشنهادی

پیشهاد می‌شود تا تنظیمات سرآیندهای سامانه به گونه‌ای باشد که از افشای اطلاعات جلوگیری کند.